



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Reverse engineering, Database security, and Web security

materials are based on security courses at other institutions

What is software reverse engineering?



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Determine and possibly change program logic
 - “Logic” ≠ Just observed behavior
- Ethics
 - Useful for good:
 - Analyze malware
 - Understand undocumented legacy code
 - Watch/read/play the stuff you paid for
 - Useful for evil
 - “Crack” software
 - (remove restrictions)
 - Find exploits
 - Cheat at games



Types of tools



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Static analysis

- **Disassembler**
 - Turn compiled program into assembly
 - Usually good, but can get confused: can't discern code from data if binary is weirdly laid out
- **Decompiler**
 - Attempts to turn assembly back into source code.
 - Usually awful at machine code, but managed code (e.g. Java, Python) can produce decent results.
- **Hex editor**
 - Understand binary data; make changes to binaries

Dynamic analysis

- **Debugger**
 - Step through running program
 - Very powerful: Gives control over time, order of execution, and content of data
 - Environment sometimes differs from regular execution in subtle ways ☹
- **Monitoring tools**
 - Watch system calls, library calls, etc.

Examples of tools



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Linux:
 - Disassembler: objdump (free), **IDA Pro** (free and paid versions),
 - Ghidra (free, from NSA!)
 - Debugger: **gdb** and its front-ends
 - Hex editor: okteta, bless, lots more...
 - Monitoring: **strace**, ltrace
- IDA Pro eats basically anything
- Windows:
 - Disassembler: **IDA Pro** (free and paid versions),
 - Ghidra (free, from NSA!)
 - Debugger: WinDBG (basic), **OllyDbg** (shareware), SoftICE (\$1000+)
 - Hex editor: XVI32, Notepad++ with plugin, etc.
 - Monitoring tools: Process Monitor, Explorer, and more.
- X86 in general: A hypervisor (VMware, KVM, etc.)

Debug or disassemble? Both.



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Disassembler gives **static** results
 - Good overview of program logic
 - But need to “mentally execute” program
 - Difficult to jump to specific functionality in the code
- Debugger is **dynamic**
 - Can set break points; fast forward to code for relevant functionality
 - Can treat complex code as “black box”
 - Not all code disassembles correctly
- Disassembler **and** debugger both required for any serious reverse engineering task

Example 1

Python decompiles very easily



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY

```
1 # Embedded file name: cryptotest.py
2 import subprocess
3 import sys, os
4 import zlib
5 import getpass
6 import socket
7 import datetime
8 import hashlib
9 from StringIO import StringIO
10 suppress_output = True
11 HEADER = 'cryptotest v1.1.0 by Dr. Tyler Bletsch (tkbletsch@ncsu.edu)'
12 color_cmd = '33'
13 color_status = '32'
14 color_tests = '44;96'
15
16 def hash_self():
17     return hash_file(sys.argv[0])
18
19
20 def hash_file(filename):
21     with open(filename, 'rb') as fp:
22         m = hashlib.md5()
23         m.update(fp.read() + 'vg' + 'slt')
24         return m.hexdigest()
```



Example 2: Minecraft



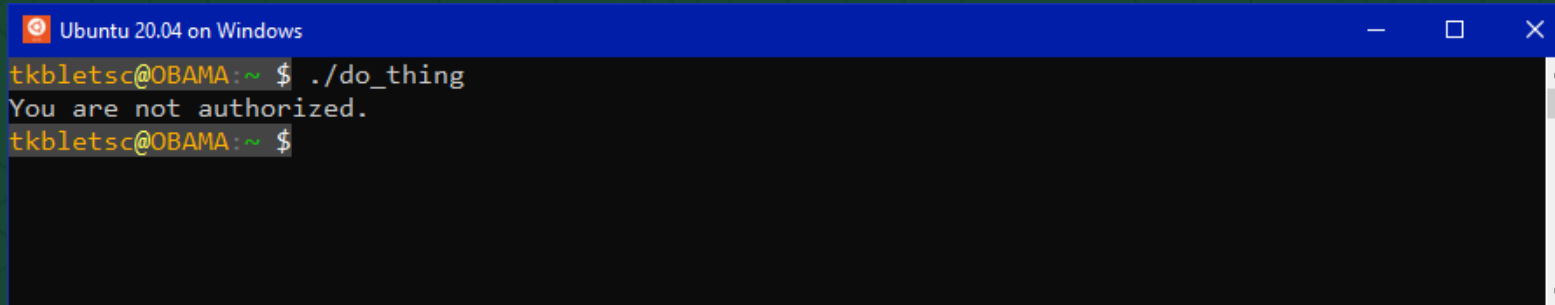
MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Minecraft is a Java program, no mod support
- All mods use something like the Mod Coder Pack (MCP):
 - “Use MCP to decompile the Minecraft client and server jar files.
 - Use the decompiled source code to create mods for Minecraft.
 - Recompile modified versions of Minecraft.
 - Reobfuscate the classes of your mod for Minecraft.”
- Entire mod community is built on reverse engineering!

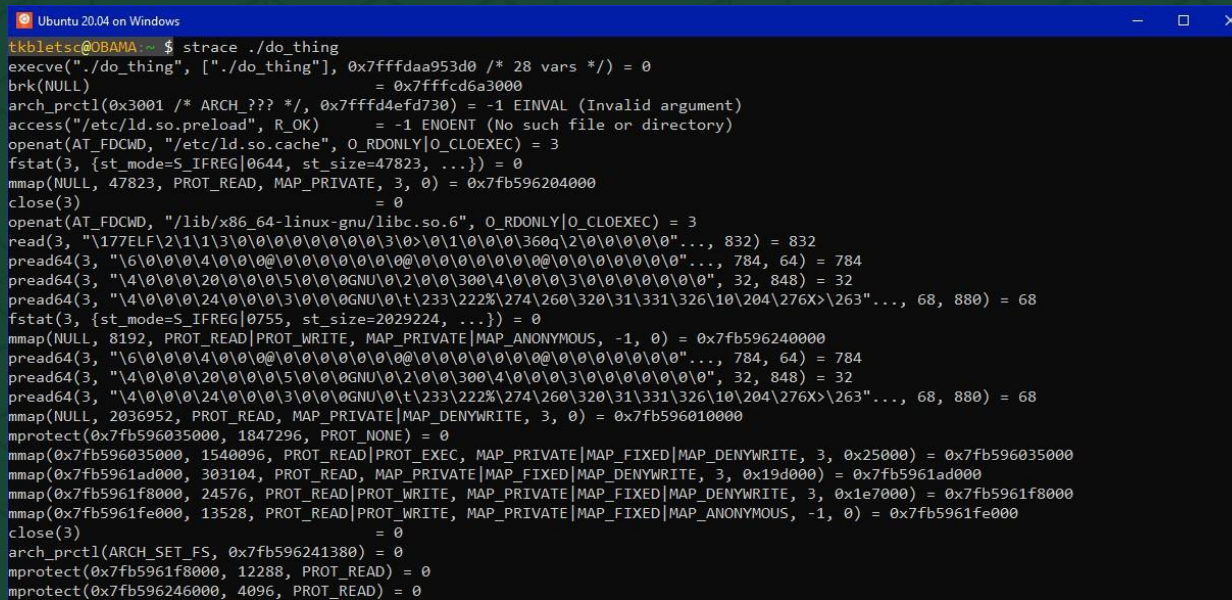


Example 3: 'do_thing'

- You have a program that mysteriously says you're not authorized:



- Could debug, disassemble, etc., but here's something cheap:
strace: find out what system calls it's doing to check authorization!



- You learn to see through the noise with practice

[illegible]

Boring stuff to start the program (load shared libraries, prepare heap)

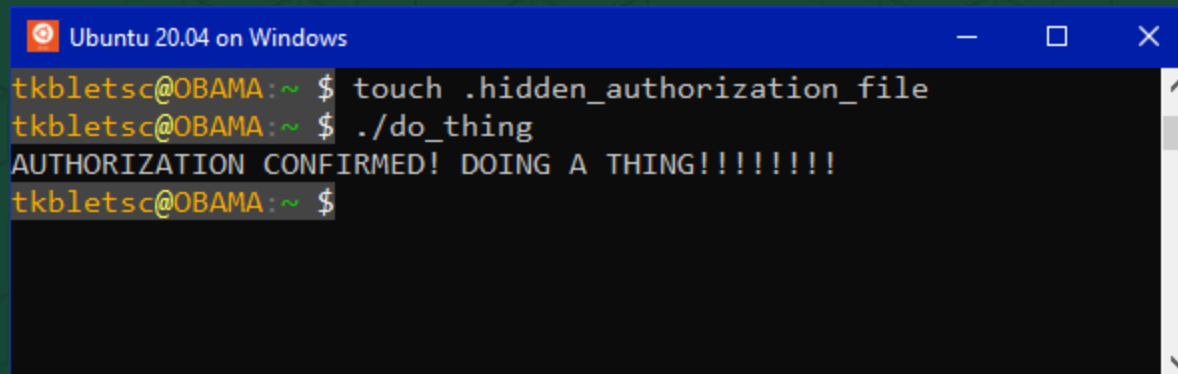
Potentially relevant syscalls

Error message
that we hate

Example 3: success

```
openat(AT_FDCWD, ".hidden_authorization_file", O_RDONLY) = -1 ENOENT (No such file or directory)
```

- It appears to check for a file called “.hidden_authorization_file” and doesn’t find it
- What if it *did* find it? Let’s try:

A terminal window titled "Ubuntu 20.04 on Windows" with a blue title bar. The terminal shows a user named tkbletsc at a machine named OBAMA. The user enters the command 'touch .hidden_authorization_file' to create a file. Then, they enter './do_thing', which results in the output 'AUTHORIZATION CONFIRMED! DOING A THING!!!!!!!!'. The prompt returns to the user.

```
tkbletsc@OBAMA:~$ touch .hidden_authorization_file
tkbletsc@OBAMA:~$ ./do_thing
AUTHORIZATION CONFIRMED! DOING A THING!!!!!!!!
tkbletsc@OBAMA:~$
```

- Success!
- But what if the program actually looked inside the file and needed to see certain data in there?
 - Can’t see *computation* from here, just IO, so that’s when you use disassembler/debugger



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Anti-reverse engineering



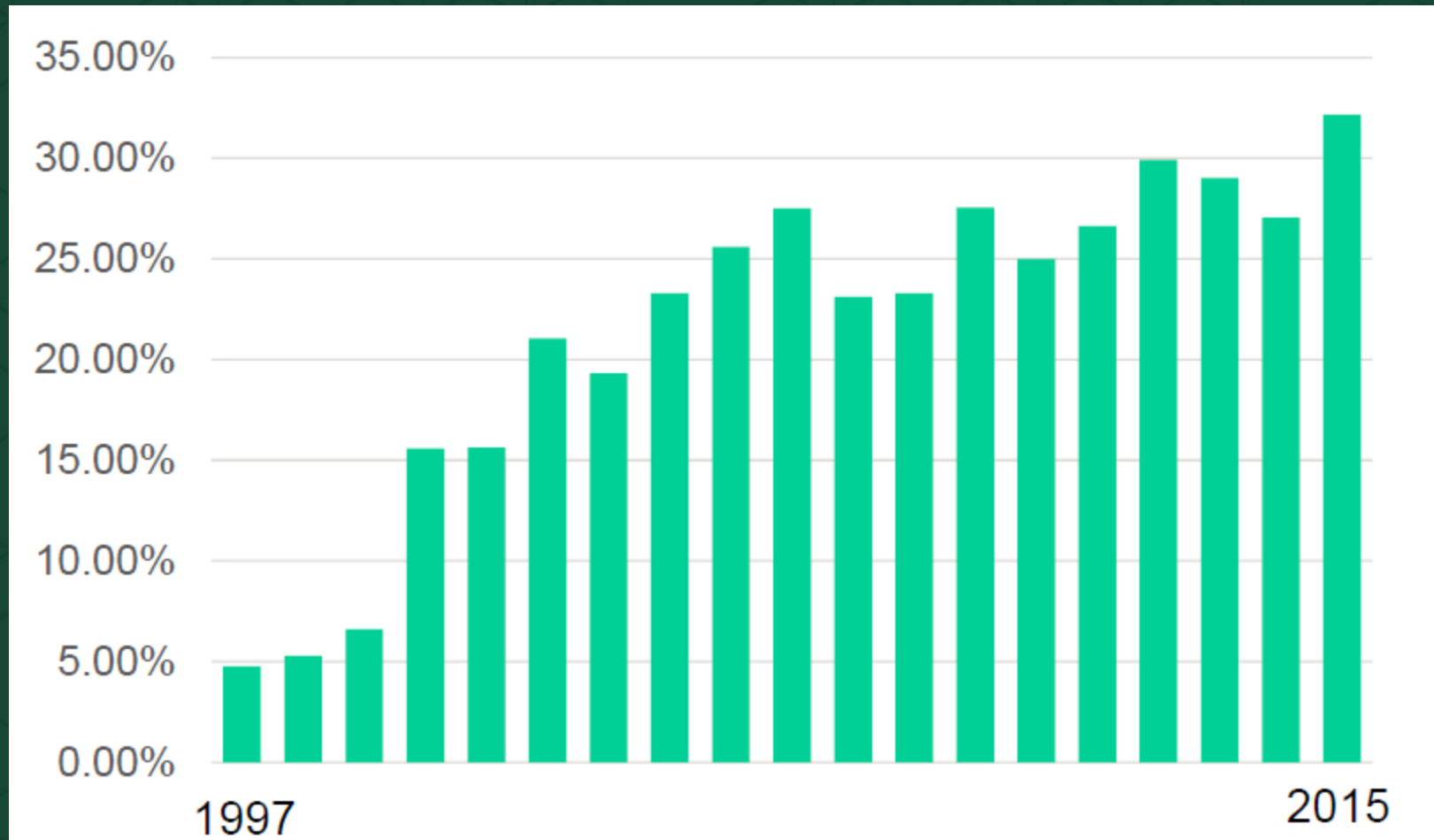
MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **Basics:**
 - Turn off debug symbols (-g)
 - Strip other symbols (e.g. “strip” tool on *NIX)
 - Consider static linking (no external calls to standard libraries to trace)
- **Anti-disassembly:**
 - Encrypted or self-modifying code
 - Code riddled with junk that is jumped over
 - Can especially confuse x86 assemblers due to variable-length instructions
- **Anti-debugging:**
 - Identify if debugger is in use (effects on real time, use of debug registers, etc.) and act differently
 - Use threads in complex ways to get less deterministic behavior
- **Tamper resistance:**
 - Hash parts of ones own code/data and verify periodically
 - The verification code is also code, though...
- **Obfuscation:**
 - Include lots of unreachable code to increase work the reverse engineer must do

Web Application Vulnerabilities



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
ROLLA, MISSOURI



How Web Browser Works?

- When you type in your web browser, say,
 - www.evilexample.com
- What will the browser do?



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

HTTP Protocol



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- HTTP request: GET /index.html
- The server response:
HTTP/1.1 200 OK Content-Type: text/xml; charset=utf-8 Content-Length:
length
...[content of index.html follows]...
- A web browser is a language interpreter, analyzes the received index.html and displays information in the browser.
 - Also request other necessary resources,
 - e.g.,



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Web Security: Some Basic Designs

Security Goals of a Web Browser



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Safe to visit an evil web site



- Safe to visit two pages at the same time
 - Address bar distinguishes them



- Allow safe delegation



Same Origin Policy

- **Origin = protocol://host:port**
 - E.g., `http://www.evil.com:7083`
- Two URLs have the same origin if the protocol, host, and port are the same for both.



Example:



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Start at:
 - <http://www.example.com/dir/page2.html>
- Same policy ?
 - <http://www.example.com/dir2/other.html>
 - <http://www.example.com/dir2/inner/another.html>
 - <http://www.example.com:81/dir/other.html>
 - <http://example.com/dir/other.html>
 - <http://v2.www.example.com/dir/other.html>
 - <https://www.example.com/dir/other.html>

Example:

- Start at: <http://www.example.com/dir/page2.html>
- Same policy ?
 - <http://www.example.com/dir2/other.html>
(same origin, only the path differs)
 - <http://www.example.com/dir2/inner/another.html>
(same origin, only the path differs)
 - <http://www.example.com:81/dir/other.html>
(not same origin, different port, http:// is port 80 by default)
 - <http://example.com/dir/other.html>
(not same origin, different hosts: www and non-www hosts)
 - <http://v2.www.example.com/dir/other.html>
(not same origin, different hosts)
 - <https://www.example.com/dir/other.html>
(not same origin, different protocols: http and https)



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Example:

- The same origin policy is a critical security mechanism to ensure web security
- It isolates potentially malicious documents.
- For example, it prevents a malicious website on the Internet from running JavaScript in a browser to read data from a third-party webmail service (which the user is signed into)



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

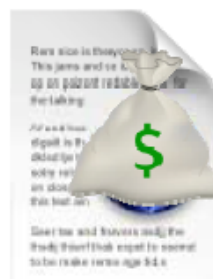
```
www.evil.com
<HTML>
  <script>
    window.open(http://www.mail.com)
    get_contacts(http://www.mail.com)
    get_inbox(http://www.mail.com)
    .....
  </script>
</HTML>
```

This script will fail to read data from www.mail.com because of the same origin policy

Using Multiple Browsers for Security



MISSOURI UNIVERSITY OF
TECHNOLOGY
MISSOURI



- Only use Chrome to log into bank
- Only use Firefox for the non-bank URLs
- Never type URLs from Firefox to Chrome

Browser Sandbox



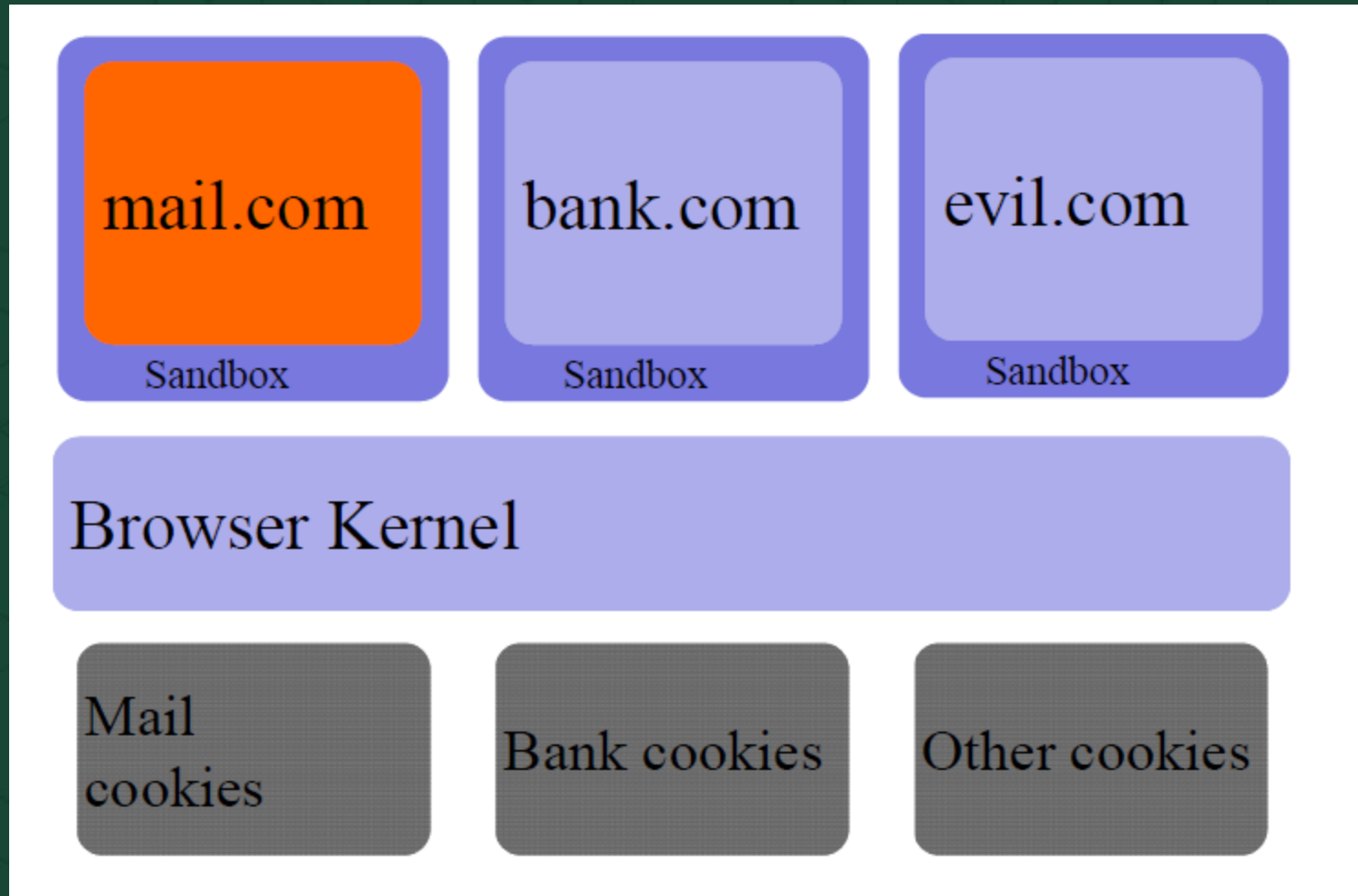
MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **Goal**
 - Run remote web applications safely
 - Limited access to OS, network, and browser data
- **Approach**
 - Isolate sites in different security contexts
 - Browser manages resources, like an OS

State Isolation



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —





MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Session Management

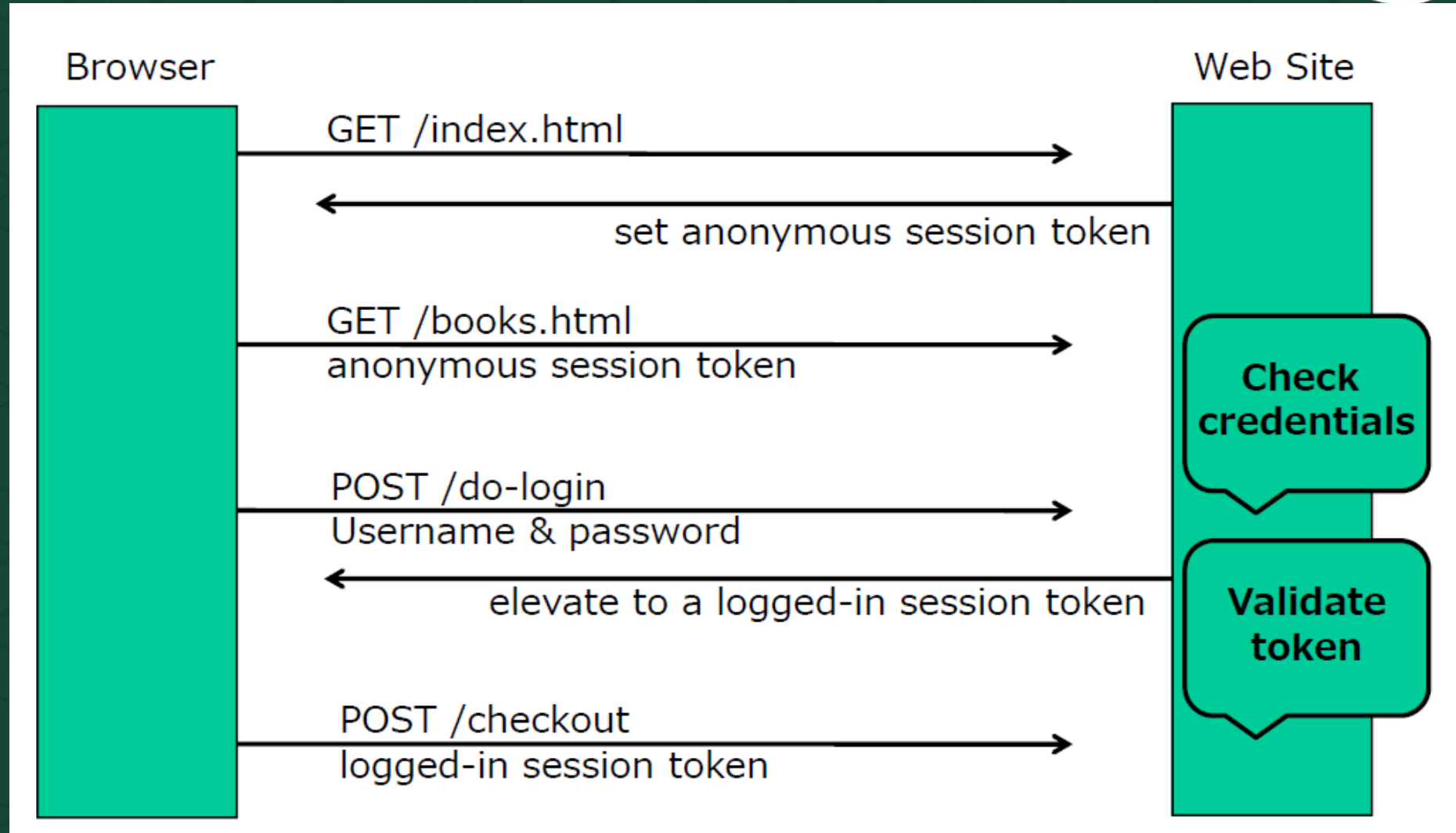
Sessions



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **A sequence of requests and responses from one browser to one (or more) sites**
 - Session can be long (Gmail - two weeks)
 - or short
- Without session management:
 - users would have to constantly re-authenticate
- **Session management:**
 - Authenticate user once
 - All subsequent requests are tied to user
 - How?

Session Tokens



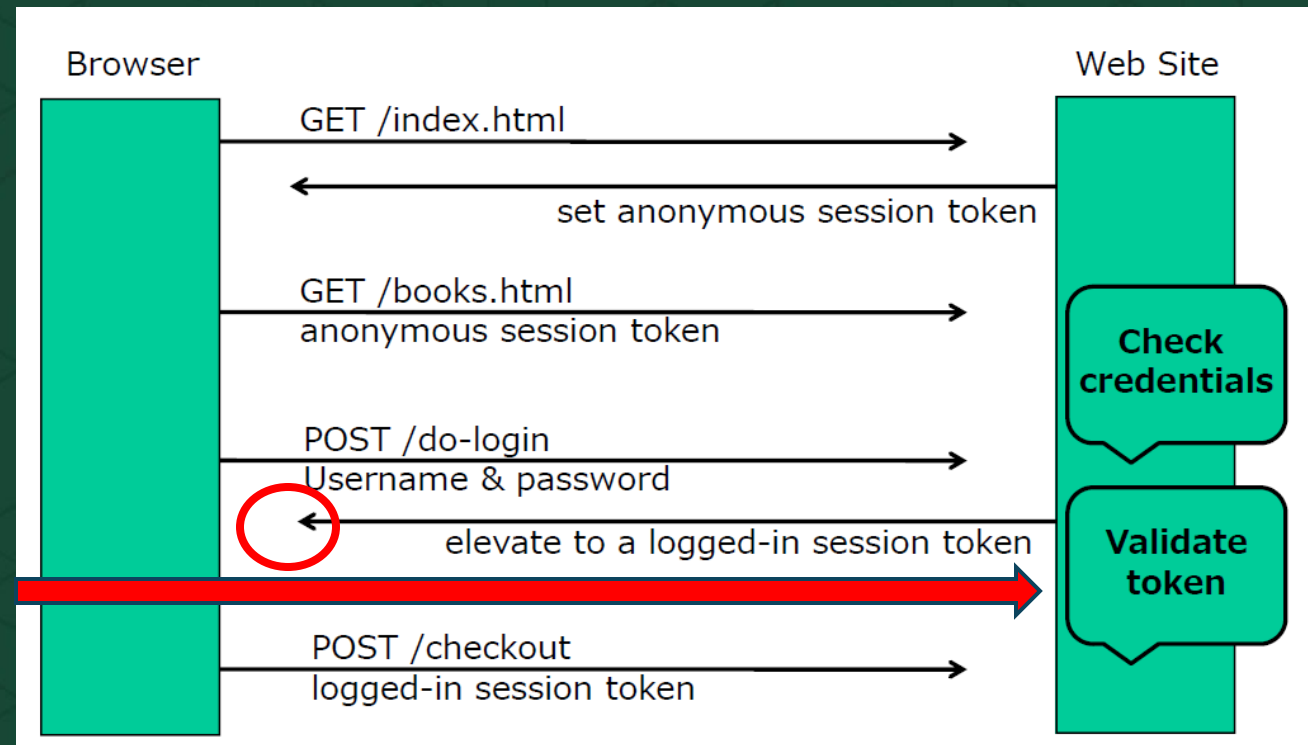
Session Hijacking



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **Attacker waits for user to login; then attacker obtains user's session token and “hijacks” session**

Attack obtains the token! And send a new request!





MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

1. Predictable Tokens

- **Example: counter (Verizon Wireless)**
 - user logs in, gets counter value, can view sessions of other users
- **Example: weak MAC (WSJ)**
 - token = {userid, $\text{MAC}_k(\text{userid})$ }
 - Weak MAC exposes k from few cookies
- **Apache Tomcat: generateSessionID()**

Session tokens must be unpredictable to attacker:
Use underlying framework (ASP, Tomcat, Jserv)

2. Cookie Theft



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **Example 1: login over SSL, but subsequent HTTP**
 - What happens at wireless cafe?
 - Other reasons why session token sent in the clear:
 - HTTPS/HTTP mixed content pages at site
 - Man-in-the-middle attacks on SSL
- **Example 2: Cross Site Scripting (XSS) exploits**
 - Coming shortly
- **Amplified by poor logout procedures:**
 - Logout must invalidate token on server

3. Session Fixation Attacks



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **Suppose attacker can set the user's session token:**
 - e.g., trick user into clicking on URL (for URL token):
www.nicewebsite.com?token=18sh3h1u2h
- **Attack: (say, using URL tokens)**
 - Attacker gets anonymous session token for site.com
 - Sends URL to user with the attacker's session token
 - User clicks on URL and logs into site.com, this elevates attacker's token to logged-in token
 - Attacker uses elevated token to hijack the user's session

Attack Example



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Attacker



1.

GET/index.html

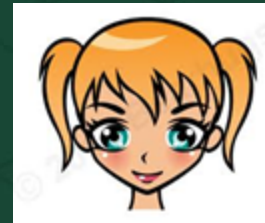
2. Set anonymous session token
token=feac4f833df12

www.bank.co
m

Attacker



3. Send a phishing email to Alice, saying that “security alert
from www.bank.com, please login to reset your password”
Link: www.bank.com?token=feac4f833df12



www.bank.com

Attacker



5. Attacker presents the token to
the server to enter Alice’s
account and may take malicious
actions like withdrawing money.

www.bank.co
m

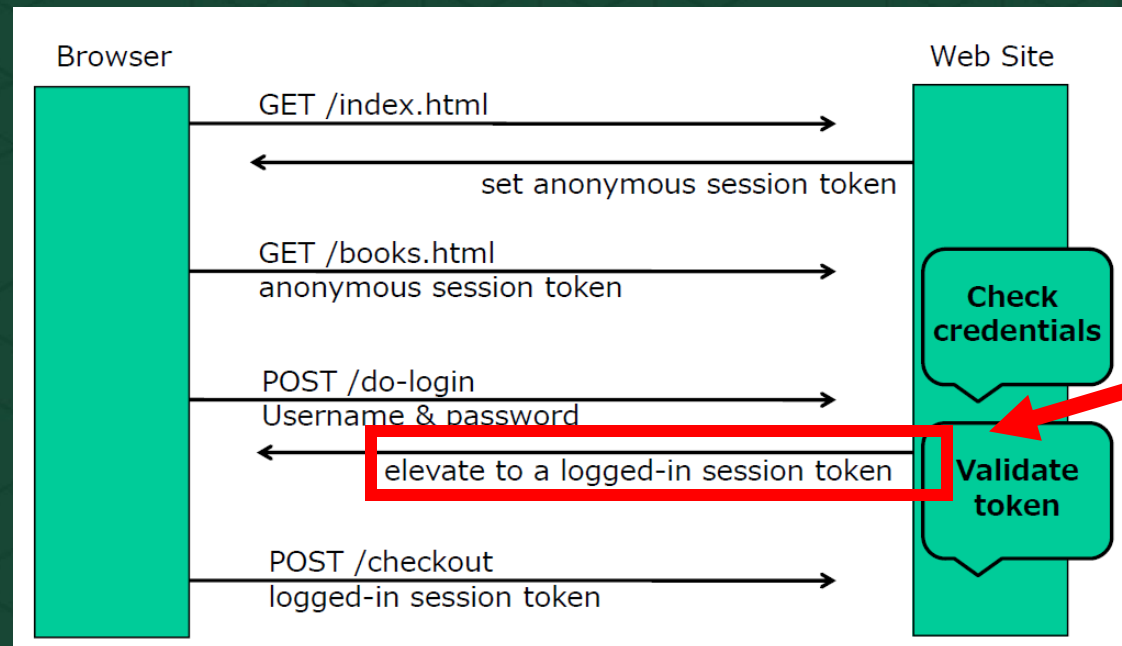
4. Alice is cautious about phishing attacks, but
she finds that www.bank.com is the genuine
link. She then clicks the link to login. This
elevates the attacker’s token to logged-in token

Session Fixation: Lesson



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- When elevating user from anonymous to logged-in always issue a new session token
- Once user logs in, token changes to value unknown to attacker
 - The attacker's token is not elevated



Session Management Takeaways



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **Session management is a key enabler of web functionality**
- **Many ways to get it wrong**
 - Predictable tokens, cookie theft, session fixation



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Cross-Site Scripting (XSS)

XSS Defined



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **An XSS vulnerability is present when an attacker can inject malicious JavaScript into pages generated by a web application.**
- **Methods for injecting malicious code:**
 - Reflected XSS (“type 1”)
 - the attack script is reflected back to the user as part of a page from the victim site
 - Stored XSS (“type 2”)
 - the attacker stores the malicious code in a resource managed by the web application, such as a database
 - Others

JavaScript



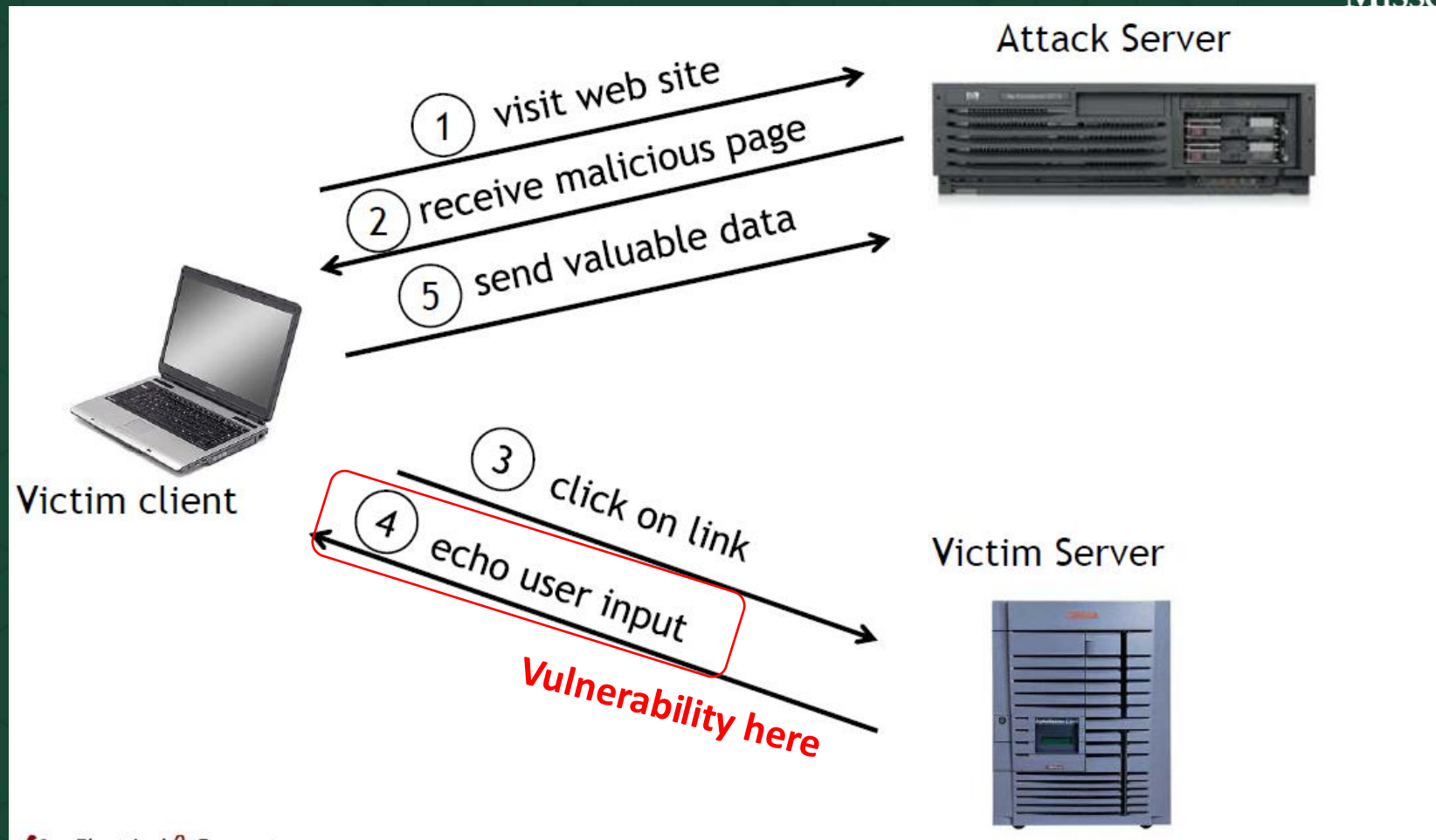
MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Essential part in WWW
- Sent from a web server to a user's web browser, which interprets and runs the script.
- Normally, a web server should have all good scripts.
 - But if a web server has a vulnerability...

Reflected XSS



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
ROLLA, MISSOURI



Example



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Search field on victim.com:
 - `http://victim.com/search.php ? term = apple`
- Server-side implementation of search.php

```
<HTML> <TITLE> Search Results </TITLE>
```

```
<BODY>
```

```
Results for <?php echo $_GET[term] ?> :
```

```
...
```

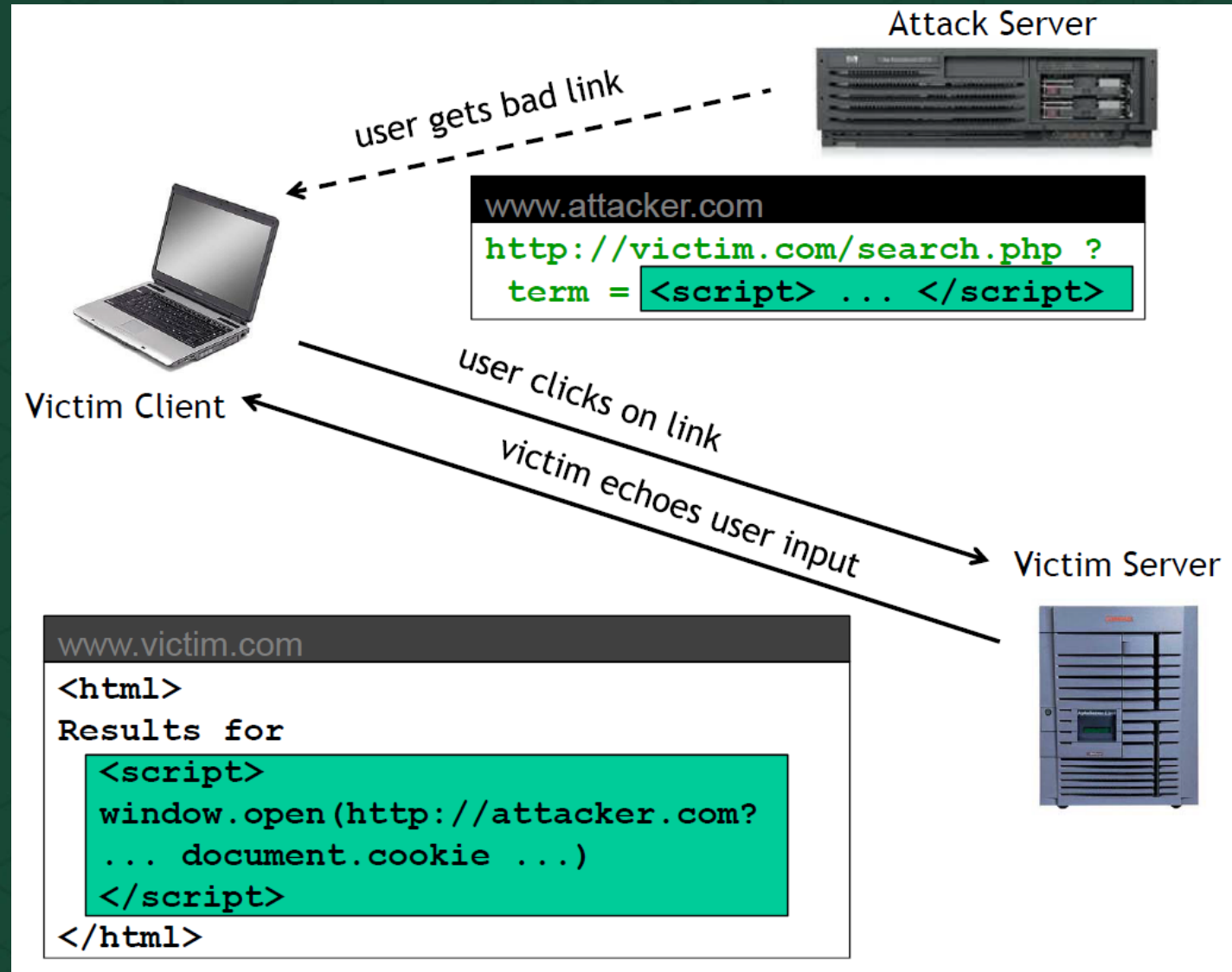
```
</BODY> </HTML>
```

Simply echo search term
into response without any
security check

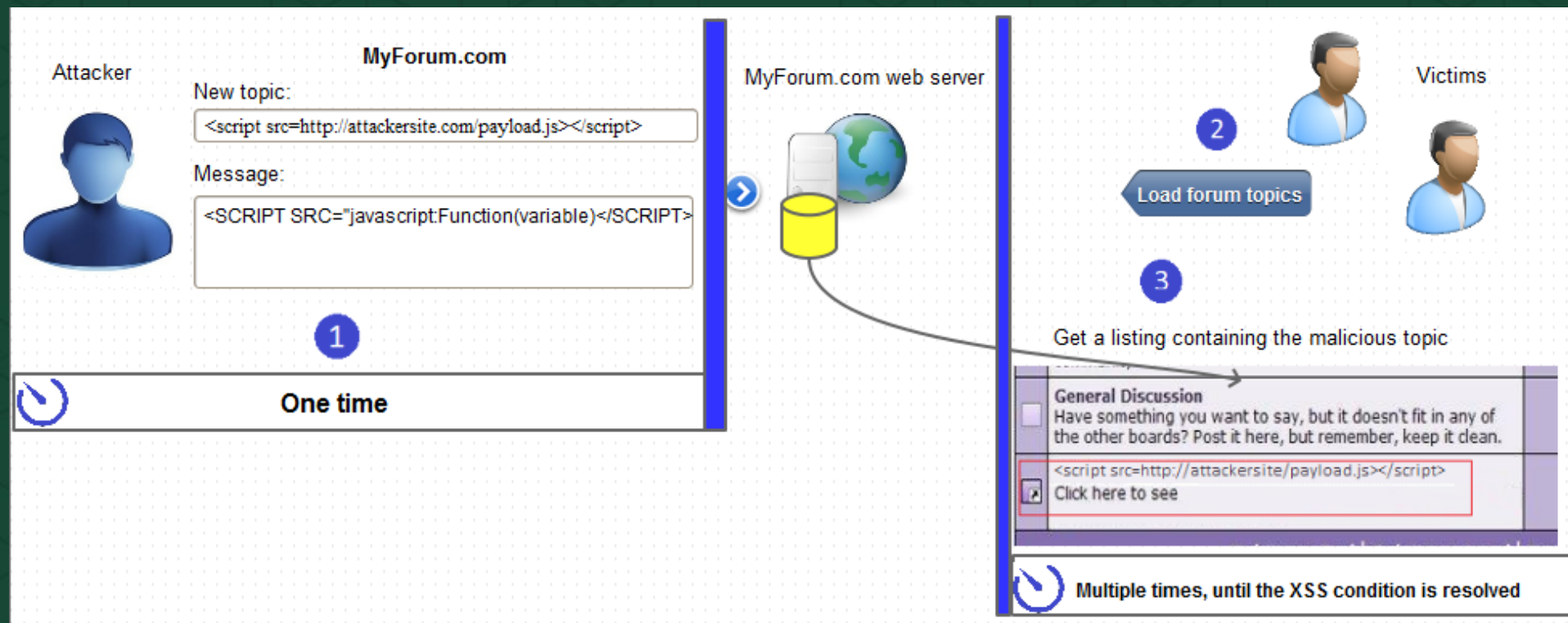
Attack Procedure



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —



Example 2: stored XSS



MySpace.com (Samy worm)

With careful JavaScript hacking:

- Samy worm infects anyone who visits an infected MySpace page ... and adds Samy as a friend
- Samy had millions of friends within 24 hours

Why XSS can happen?



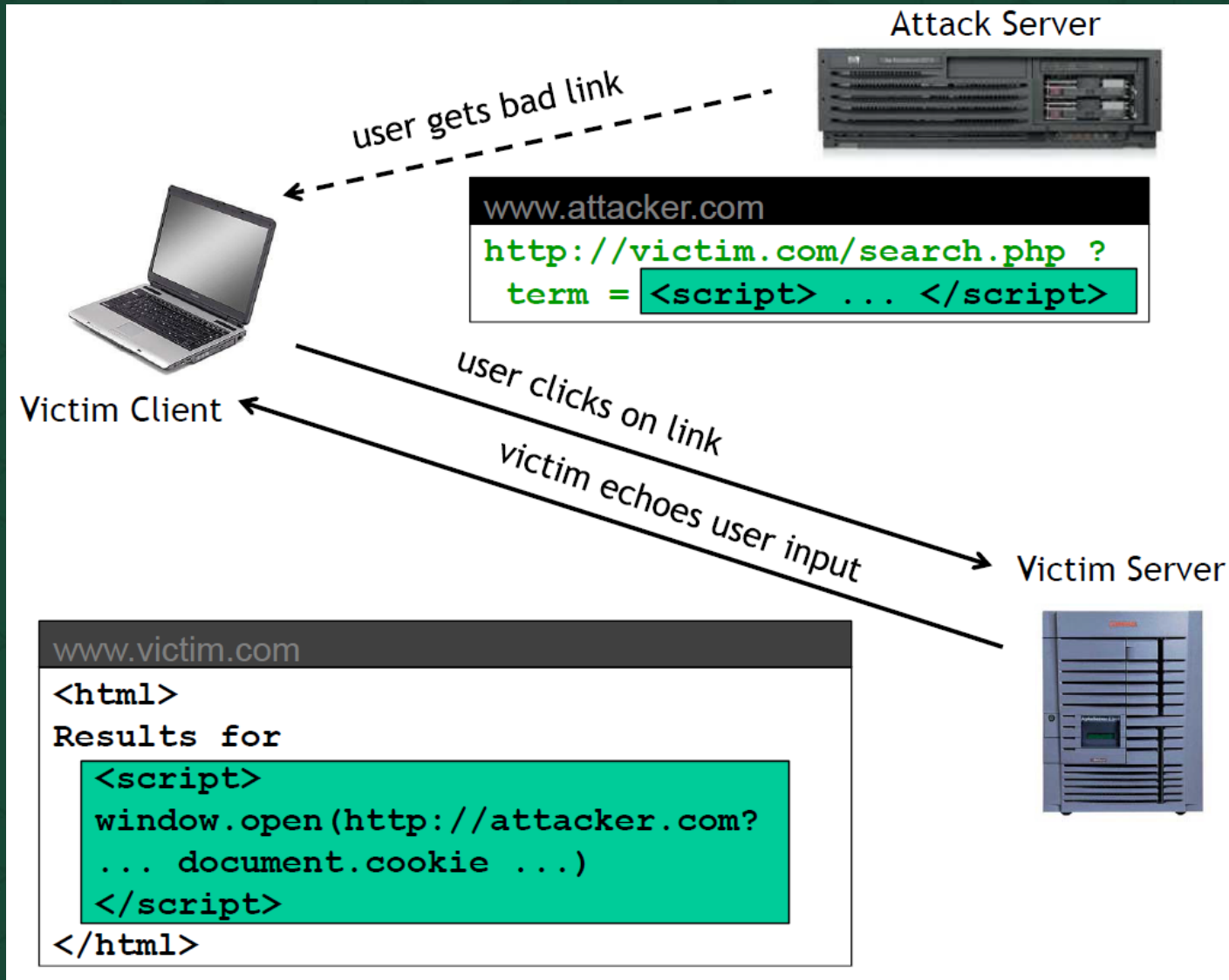
MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **In XSS, attacker takes advantage of browser's trust in web server**
 - Server is tricked into producing output that browser interprets in a way that harms user
 - E.g., browser sends private data to attacker

Defense starts from?



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —



How to protect yourself



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **The best way to protect against XSS attacks:**
 - Validates all headers, cookies, query strings, form fields, and hidden fields (i.e., all parameters) against a rigorous specification of what should be allowed
- Implement 'positive' security policy that specifies what is allowed
 - Negative or attack signature-based policies are difficult to maintain and are likely to be incomplete

Input Data Validation and Filtering



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **Never trust client-side data**
 - Best: allow only what you expect
- **Remove/encode special characters**
 - Many encodings, special chars!
 - E.g., long (non-standard) UTF-8 encodings

Output Filtering / Encoding



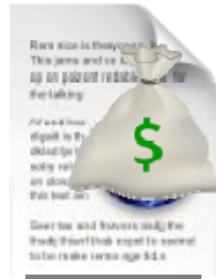
MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **Remove / encode (X)HTML special chars**
 - < for <, > for >, " for “ ...
- **Allow only safe commands (e.g., no <script>...)**
- **Caution: “filter evasion” tricks**
 - XSS Filter Evasion Cheat Sheet
(https://cheatsheetseries.owasp.org/cheatsheets/XSS_Filter_Evasion_Cheat_Sheet.html)
 - E.g., Case Insensitive XSS Attack Vector `<IMG SRC=JaVaScRiPt:alert('XSS')>`
 - E.g, Malformed IMG Tags `<IMG """"><SCRIPT>alert("XSS")</SCRIPT>"\>`

Again, Can Using Multiple Browsers be good for Defending against XSS?



MISSOURI UNIVERSITY OF
TECHNOLOGY
MISSOURI



- Only use Chrome to log into bank
- Only use Firefox for the non-bank URLs
- Never type URLs from Firefox to Chrome

SQL Injection Attack



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY

ROLLA, MISSOURI



Database and SQL Introduction



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Standard language for querying and manipulating data

Structured Query Language

Many standards out there:

- ANSI SQL, SQL92 (a.k.a. SQL2), SQL99 (a.k.a. SQL3),

Introduction to SQL



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Data Definition Language (DDL)
 - Create/alter/delete tables and their attributes
 - Following lectures...
- Data Manipulation Language (DML)
 - Query one or more tables – discussed next!
 - Insert/delete/modify tuples in tables

Database Management Tables

Attribute names

MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Table name

Product

PName	Price	Category	Manufacturer
Gizmo	\$19.99	Gadgets	GizmoWorks
Powergizmo	\$29.99	Gadgets	GizmoWorks
SingleTouch	\$149.99	Photography	Canon
MultiTouch	\$203.99	Household	Hitachi

Tuples or rows



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
ROLLA, MISSOURI

Tables Explained

- The *schema* of a table is the table name and its attributes:

Product(PName, Price, Category, Manufacturer)

- A *key* is an attribute whose values are unique; we underline a key

Product(PName, Price, Category, Manufacturer)

Data Types in SQL



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Atomic types:
 - Characters: CHAR(20), VARCHAR(50)
 - Numbers: INT, BIGINT, SMALLINT, FLOAT
 - Others: MONEY, DATETIME, ...
- Every attribute must have an atomic type.

Tables Explained



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- A tuple = a record
 - Restriction: all attributes are of atomic type
- A table = a set of tuples
 - Like a list...
 - ...but it is unordered: no **first()**, no **next()**, no **last()**.

SQL Query



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Basic form: (plus many many more bells and whistles)

```
SELECT <attributes>  
FROM <one or more relations>  
WHERE <conditions>
```

Simple SQL Query



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Product

<u>PName</u>	Price	Category	Manufacturer
Gizmo	\$19.99	Gadgets	<u>GizmoWorks</u>
Powergizmo	\$29.99	Gadgets	GizmoWorks
SingleTouch	\$149.99	Photography	Canon
<u>MultiTouch</u>	\$203.99	Household	Hitachi

```
SELECT *  
FROM Product  
WHERE category='Gadgets',
```

“selection”



<u>PName</u>	Price	Category	Manufacturer
Gizmo	\$19.99	Gadgets	GizmoWorks
Powergizmo	\$29.99	Gadgets	<u>GizmoWorks</u>

Simple SQL Query



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Product

PName	Price	Category	Manufacturer
Gizmo	\$19.99	Gadgets	GizmoWorks
Powergizmo	\$29.99	Gadgets	GizmoWorks
SingleTouch	\$149.99	Photography	Canon
MultiTouch	\$203.99	Household	Hitachi

```
SELECT PName, Price, Manufacturer  
FROM Product  
WHERE Price > 100
```



“selection” and
“projection”

PName	Price	Manufacturer
SingleTouch	\$149.99	Canon
MultiTouch	\$203.99	Hitachi

Notation



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Input Schema

Product(PName, Price, Category, Manufacturer)

```
SELECT PName, Price, Manufacturer  
FROM   Product  
WHERE  Price > 100
```



Answer(PName, Price, Manufacturer)

Output Schema

Database Queries with PHP



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **Sample PHP**

```
$recipient = $_POST['recipient'];
```

```
$sql = "SELECT PersonID FROM People WHERE Username='$recipient' ";
```

```
$rs = $db->executeQuery($sql);
```

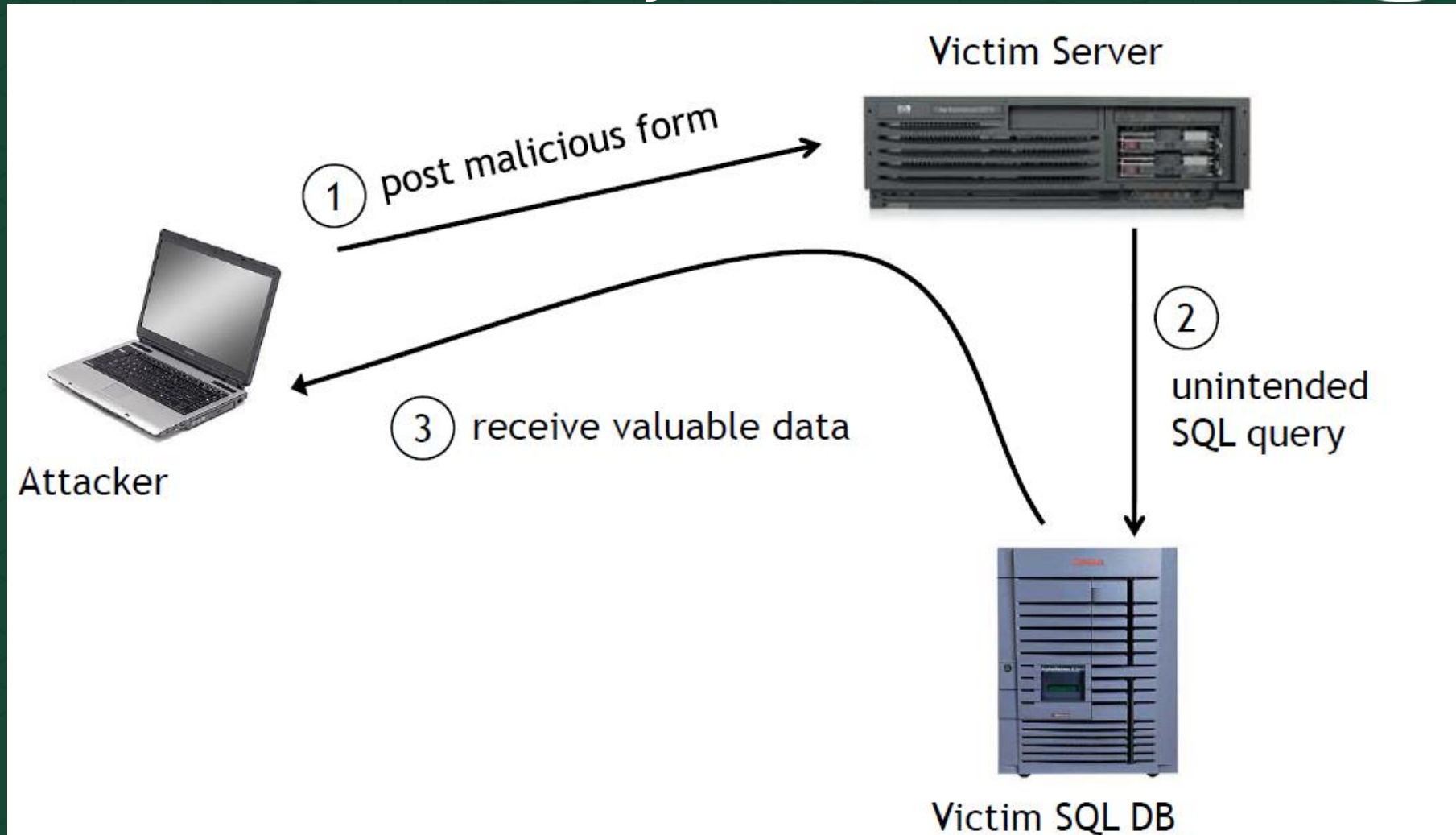
- **Normal:**

- \$recipient save the name of the recipient, e.g., “Tom”, “Mike”, “Joe”, ...

- **Problem:**

- Untrusted user input ‘recipient’ is embedded directly into SQL command

Basic Picture: SQL Injection



CardSystems Attack



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **CardSystems**

- credit card payment processing company
- SQL injection attack in June 2005
- put out of business

- **The Attack**

- 263,000 credit card #s stolen from database
- credit card #s stored unencrypted
- 43 million credit card #s exposed

April 2008 SQL Vulnerabilities



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

A screenshot of a web browser window displaying a blog post. The browser's address bar shows a URL starting with 'http://'. The page title is 'Microsoft Web Servers Hacked...'. The browser interface includes a search bar, navigation icons, and a status bar at the bottom showing 'Done' and 'Internet' connectivity. The blog post is from 'SECURITY FIX' by Brian Krebs. The main text discusses a security flaw in Microsoft's Internet Information Services (IIS) Web servers, mentioning that hundreds of thousands of web sites have been hacked. It also references a Microsoft advisory (951306) and provides links to further information, including a 'nice writeup' from Shadowserver.org and the SANS Internet Storm Center.

SECURITY FIX **BRIAN KREBS**
Brian Krebs on Computer Security

[About This Blog](#) | [Archives](#) | [XML RSS Feed](#) ([What's RSS?](#))

Hundreds of Thousands of Microsoft Web Servers Hacked

Hundreds of thousands of Web sites - including several at the **United Nations** and in the U.K. government -- have been hacked recently and seeded with code that tries to exploit security flaws in **Microsoft Windows** to install malicious software on visitors' machines.

The attackers appear to be breaking into the sites with the help of a security vulnerability in Microsoft's [Internet Information Services](#) (IIS) Web servers. In [an alert issued last week](#), Microsoft said it was investigating reports of an unpatched flaw in IIS servers, but at the time it noted that it wasn't aware of anyone trying to exploit that particular weakness.

in [a post](#) to one of its blogs, Microsoft
flaw in IIS: "...our investigation has
own vulnerabilities being exploited.
bility in Internet Information Services
also determined that these attacks are
ity Advisory (951306). The attacks
its and are not issues related to IIS
)L technologies. SQL injection attacks
nmands in an application's database.
cks the developer of the Web site or
actices outlined here. Our counterparts
ost with a wealth of information for
can take to minimize their exposure to

these types of attacks by minimizing the attack surface area in their code and server configurations."

Shadowserver.org has [a nice writeup](#) with a great deal more information about the mechanics behind this attack, as does the [SANS Internet Storm Center](#).

Main Steps in This Attack



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- 1. Use Google to find sites using a particular ASP style vulnerable to SQL injection**
- 2. Use SQL injection on these sites to modify the page to include a link to a Chinese site nihaorr1.com**
 - The site (nihaorr1.com) serves JavaScript that exploits vulnerabilities in IE, RealPlayer, QQ Instant Messenger
 - **Steps (1) and (2) are automated in a tool that can be configured to inject whatever you like into vulnerable sites**

Example: Buggy Login Page (ASP)



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY

MISSOURI

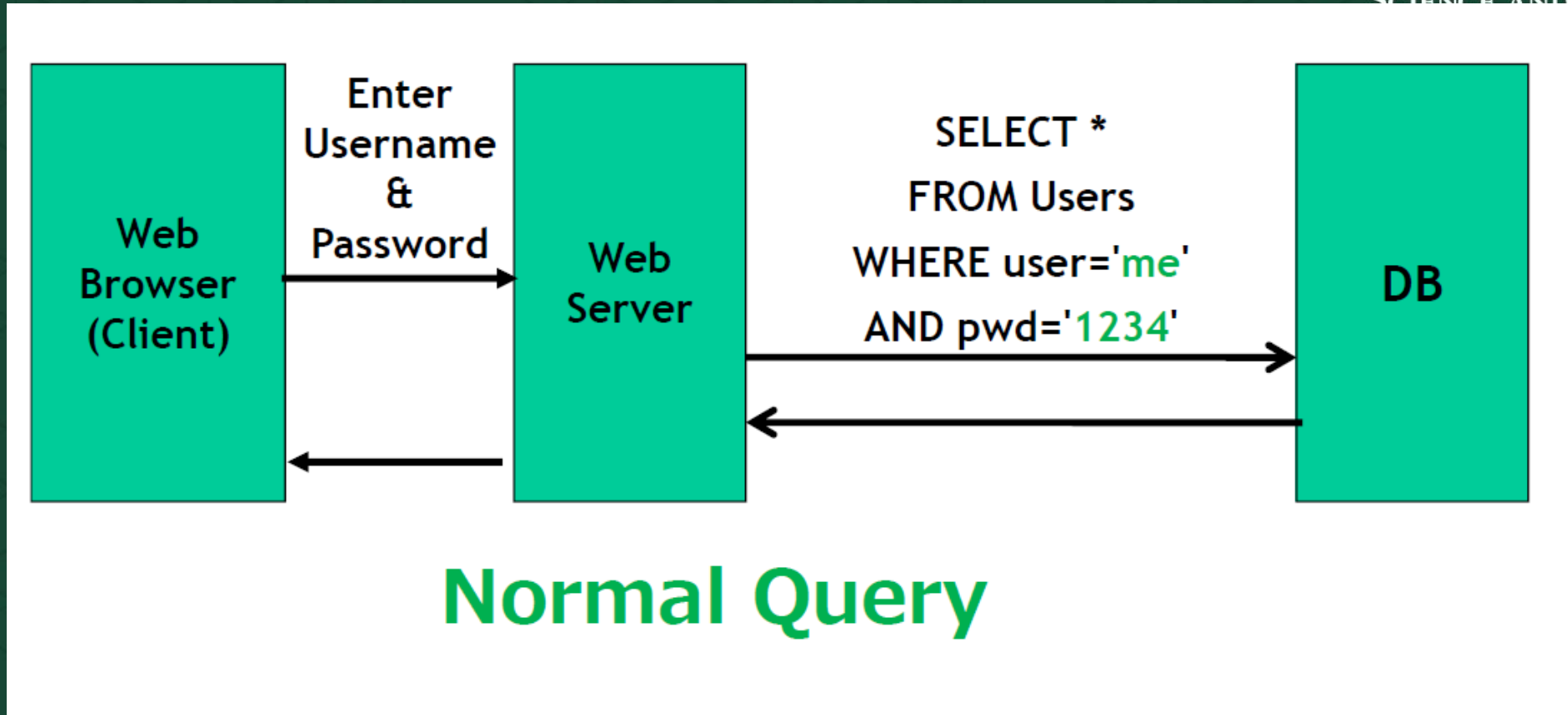
```
set ok = execute( "SELECT * FROM Users
    WHERE user=' ' & form("user") & " '
    AND    pwd=' ' & form("pwd") & " ' " );

if not ok.EOF
    login success
else fail;
```

Normal Query



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
MISSOURI



Bad Input



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Suppose user becomes

' or 1=1 --

- The server verification script becomes

```
ok = execute( SELECT ...  
               WHERE user= ' ' or 1=1  -- ... )
```



causes rest of line to be ignored

- Bad news: easy to log in to many sites this way

Even Worse



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Suppose user is

```
' ; DROP TABLE Users --
```

- Then, the script does

```
ok = execute( SELECT ...  
WHERE user= ' ' ; DROP TABLE Users ... )
```

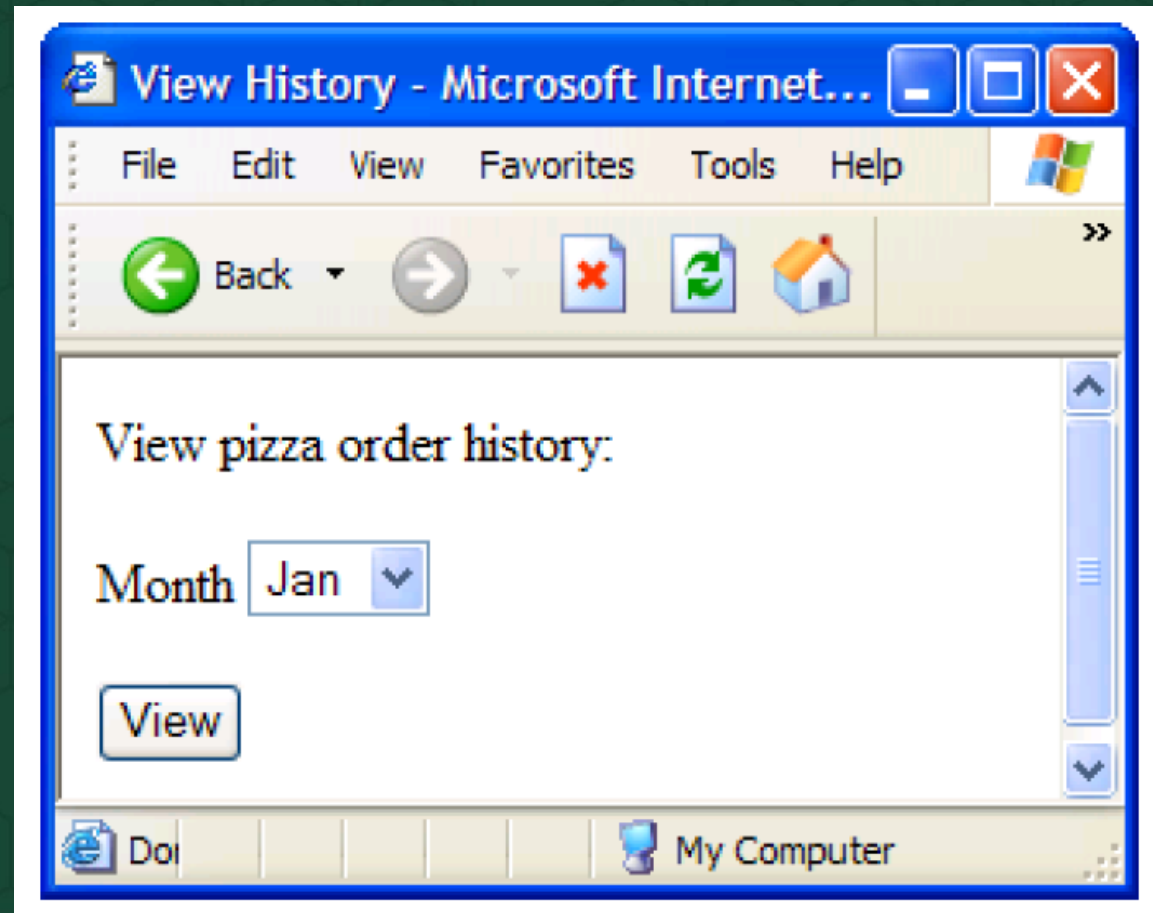
- Deletes user table

- Similarly: attacker can add users, reset pwds, etc.

Get Private Info



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —



Get Private Info



UNIVERSITY OF
TECHNOLOGY
MISSOURI

SQL Query

```
"SELECT pizza, toppings, quantity, date  
FROM orders  
WHERE userid=" . $userid .  
"AND order_month=" . _GET['month']
```

What if:

```
month = "  
0 AND 1=0  
UNION SELECT name, CC_num, exp_mon, exp_year  
FROM creditcards "
```

Get Private Info



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

The screenshot shows a Mozilla Firefox browser window titled "Order History - Mozilla Firefox". The address bar displays "https://w" followed by a "Go" button and a search icon. The main content area has the heading "Your Pizza Orders in October:" and a red warning "Credit Card Info Compromised". Below this is a table with four columns: "Pizza", "Toppings", "Quantity", and "Order Day". The table lists three orders: Neil Daswani (1234 1234 9999 1111, 11, 2007), Christoph Kern (1234 4321 3333 2222, 4, 2008), and Anita Kesavan (2354 7777 1111 1234, 3, 2007). A fourth row contains "....". The status bar at the bottom says "Done".

Pizza	Toppings	Quantity	Order Day
Neil Daswani	1234 1234 9999 1111	11	2007
Christoph Kern	1234 4321 3333 2222	4	2008
Anita Kesavan	2354 7777 1111 1234	3	2007
....			

Preventing SQL Injection



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **Never build SQL commands yourself!**
 - Use parameterized/prepared SQL
 - Use ORM (object-relational-mapping) framework, e.g.,
 Person p = repository.GetPerson(10);
 String name = p.getFirstName();

Summary



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **Tons of features and complexity we haven't covered**
- **Lots of scary, simple attacks**
 - Many due to trusting input
- **Constant drive for new features**
- **Many ways to set policy**
 - mistakes that make attacks possible